

AVANTSERVICES.COM.BR



4Shark

Relatório de teste de intrusão

AVANT

Somos o futuro.

Agilidade e eficácia a um nível que a sua empresa precisa.

A atualidade exige agilidade e eficácia a um nível que as empresas precisam de muito foco em seus negócios. Essa é a essência da Avant. Somos parceiros dos nossos clientes e buscamos somar nossa expertise ao seu dia a dia.

Mais do que uma empresa que vende licenças de software, nós buscamos ser a melhor solução para que nossos clientes confiem em nós e tenham total tranquilidade para manter o foco em sua operação.

Assim, iremos juntos e Avant!

ÍNDICE

SUMÁRIO EXECUTIVO.....	4
Abordagem.....	5
Resumo das Descobertas.....	5
Detalhes de Vulnerabilidades Identificadas	9
Apêndice A - Definição da Severidade das Vulnerabilidades	28
Estabelecendo a Severidade	28

SUMÁRIO EXECUTIVO

Visão Geral do Projeto

A Avant Services foi contratada pelo cliente, 4Shark para a realização de um Teste de Intrusão no escopo definido.

Objetivos

- Identificar problemas críticos e de alto risco que possam representar ameaça para a organização.
- Testar ativamente o ambiente em busca de vulnerabilidades de segurança, utilizando o guia OWASP Web Security Testing Guide, PCI-DSS, PTES e outras frameworks para uma cobertura completa de testes.
- Identificar possíveis falhas de lógica de negócios que possam impactar negativamente a organização.
- Avaliar a segurança web que se enquadra no escopo.
- Revisar o ambiente em busca de software desatualizadas de terceiros que possam gerar alguma insegurança no ambiente.

Vulnerabilidades Encontradas

1 Alto
8 Médio
5 Baixo

14 Falhas Encontradas

Escopo

- <https://beta.app4shark.com>
<https://beta001.app4shark.com>

Datas

2026-03-29

Kickoff inicial

2026-03-27 - 2026-03-30

Teste Ativo

30/03/2026

Entrega de relatório

Abordagem

O principal objetivo da avaliação é testar meticulosamente o escopo definido e identificar possíveis falhas que possam representar um risco para a organização. Assim como uma revisão de carro, o teste pode ser utilizado para identificar problemas ainda em estágio inicial, antes que eles se tornem problemas mais sérios.

A Avant Services usa uma metodologia padrão de segurança cibernética para garantir a cobertura completa de testes do escopo. Esse processo incorpora técnicas de teste manuais e automatizadas.

Os testes manuais, conduzidos por um avaliador experiente, podem revelar vários tipos de vulnerabilidades que não podem ser identificadas por meio de ferramentas automatizadas. Isso inclui falhas de lógica de negócios e falhas de autorização, embora não seja uma limitação.

O teste automatizado se destaca em situações em que uma grande quantidade de variações de input no aplicativo é requerida. Normalmente, o teste automatizado funciona bem com Cross-Site Scripting (XSS), SQL Injection e outros testes relacionados à validação de entrada.

A metodologia da Avant Services se baseia no Penetration Testing Execution Standard (PTES), OWASP Web Security Testing Guide (WSTG), e outros. OWASP é uma organização sem fins lucrativos, líder de mercado, dedicada a melhorar a segurança de software.

Resumo das Descobertas

A equipe cyber identificou as seguintes vulnerabilidades durante o teste de intrusão:

Risco	ID	Vulnerabilidade	Status
Alto	F-1	Aplicação Configurada em Modo Development em Produção	Vulnerável
Médio	F-2	Ausência de Rate Limiting em Endpoint de Autenticação	Vulnerável
Médio	F-3	CSP Vulnerável a Bypass Através de Domínios em Whitelist	Vulnerável
Médio	F-4	Política CSP Permite Estilos Inline Não Confiáveis	Vulnerável
Médio	F-5	Endpoint de Preview de E-mails Acessível sem Autenticação	Vulnerável

Médio	F-6	Exposição de Informações Sensíveis em Páginas de Erro Detalhadas	Vulnerável
Médio	F-7	Cookie de Sessão Sem Atributos de Segurança Adequados	Vulnerável
Médio	F-8	Exposição de Token de Acesso do Rollbar no Código JavaScript	Vulnerável
Médio	F-9	Vazamento de Informações Através de Páginas de Erro Detalhadas	Vulnerável
Baixo	F-10	Configuração CORS Não Implementada Explicitamente	Vulnerável
Baixo	F-11	Ausência de Header Strict-Transport-Security em Recursos Estáticos	Vulnerável
Baixo	F-12	Ausência de Proteção Anti-Clickjacking	Vulnerável
Baixo	F-13	Ausência de Header Strict Transport Security (HSTS)	Vulnerável
Baixo	F-14	Exposição de Credenciais do New Relic no Código JavaScript	Vulnerável

Até o momento em que este relatório foi produzido, nenhuma outra vulnerabilidade foi identificada. Consulte os detalhes das vulnerabilidades abaixo para obter uma descrição técnica dos problemas, incluindo medidas que podem ser tomadas para mitigar o risco.

OBSERVAÇÕES ADICIONAIS

- **Autenticação – Controles de Autenticação - Deficiências Críticas Identificadas** Durante a avaliação dos mecanismos de autenticação da aplicação, foram identificadas diversas vulnerabilidades significativas. O principal achado relaciona-se à ausência de rate limiting adequado no endpoint de autenticação (/sessions), conforme evidenciado pelos achados 'Ausência de rate limiting em endpoint de autenticação'. Esta deficiência permite que atacantes realizem ataques de força bruta contra credenciais de usuários sem limitações por IP ou conta, representando um risco significativo à segurança das contas de usuários. Adicionalmente, o cookie de sessão '_four_shark_app' não possui o atributo Secure configurado adequadamente, conforme identificado no achado 'Cookie de sessão sem atributos de segurança adequados', permitindo potencial transmissão através de conexões não criptografadas.
- **Autorização – Controles de Autorização - Falhas de Acesso Críticas** A análise dos controles de autorização revelou vulnerabilidades críticas que comprometem significativamente a segurança da aplicação. Os achados mais preocupantes incluem o 'Endpoint de informações do Rails acessível em produção', que expõem informações sensíveis sobre a arquitetura da aplicação, rotas internas, versões de gems e configurações sem qualquer mecanismo de autenticação. Complementarmente, foi identificado o 'Endpoint de visualização de e-mails acessível sem autenticação' (/rails/mailers), que embora não contenha conteúdo ativo, revela informações sobre a estrutura de comunicação da aplicação. Estas falhas representam uma exposição crítica de informações que podem facilitar ataques subsequentes mais elaborados.
- **Validação de Entrada de Dados – Validação de Entrada - Análise Sem Achados Críticos** Durante esta avaliação, não foram identificadas vulnerabilidades específicas relacionadas à validação inadequada de entrada de dados, como injeção SQL, cross-site scripting (XSS) baseado em entrada de usuário, ou outras falhas de sanitização de dados. Embora tenham sido observadas exposições de informações em páginas de erro e configurações inadequadas de desenvolvimento, estas não se caracterizam como falhas diretas de validação de entrada.
- **Firewall de Aplicativo Web – WAF e Cabeçalhos de Segurança - Configurações**

Inadequadas Identificadas A análise dos cabeçalhos de segurança e mecanismos de proteção revelou diversas deficiências importantes. Foi identificada 'Configuração de CSP permite execução de estilos não confiáveis' e 'CSP vulnerável a bypass através de domínios em whitelist', indicando que a política de segurança de conteúdo implementa diretrizes permissivas que podem ser exploradas para ataques de injeção de código. Adicionalmente, foram observadas deficiências no 'Strict Transport Security (HSTS) não implementado adequadamente' em alguns recursos, e a identificação de resposta 'enquadrável' que pode levar a ataques de Clickjacking. A 'Configuração CORS não implementada adequadamente' também foi observada, embora com impacto menor. Estas configurações inadequadas reduzem significativamente as proteções da aplicação contra ataques do lado cliente e podem facilitar diversos vetores de ataque.

RECURSOS ADICIONAIS

Planilha de Gerenciamento de Sessão

https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html

Planilha para Validação de Entrada de Dados

https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html

Planilha de Autenticação

https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html

Planilha para Autorização

https://cheatsheetseries.owasp.org/cheatsheets/Authorization_Cheat_Sheet.html

Guia de Testes da OWASP Web Security

<https://owasp.org/www-project-web-security-testing-guide/v42/>

OWASP Guia para Programação Segura

https://owasp.org/www-pdf-archive/OWASP_SCP_Quick_Reference_Guide_v2.pdf